2️⃣

Mantenha a segurança: Gerenciamento de Riscos

Domínios de segurnaça do CISSP

Postura de Segurança - Refere-se à capacidade de uma organização de gerenciar sua defesa de ativos e dados críticos e reagir às mudanças.

Segurança e gerenciamento de riscos

Focados na definição de metas de segurança, redução de risco, conformidade, continuidade dos negócios e regulamentações legais.

Ao definir metas e objetivos de segurança, as organizações podem reduzir os riscos a ativos e dados críticos, como PII ou informações de identificação pessoal.

Todas as organizações devem desenvolver sua postura de segurança. A postura de segurança é a capacidade da organização de gerenciar sua defesa de recursos e dados críticos e reagir a mudanças. Os elementos do domínio de gerenciamento de segurança e de riscos que afetam a postura de segurança de uma organização incluem:

- Objetivos e metas de segurança
- Processos de redução de riscos
- Conformidade
- Planos de continuidade de negócios
- Reguladores legais
- Ética profissional e organizacional

A segurança das informações, ou InfoSec, também está relacionada a esse domínio e refere-se a um conjunto de processos estabelecidos para proteger as informações. Uma organização pode usar manuais e implementar treinamentos como parte de seu programa de segurança e gerenciamento de riscos, com base em suas necessidades e no risco percebido. Há muitos processos de design de InfoSec, tais como

- Resposta a incidentes
- Gerenciamento de vulnerabilidade
- Segurança de aplicativos
- Segurança na nuvem
- Segurança da infraestrutura

Como exemplo, uma equipe de segurança pode precisar alterar a forma como as informações de identificação pessoal (PII) são tratadas para aderir ao Regulamento Geral de Proteção de Dados (GDPR) da União Europeia.

Mistigação de riscos

SIgnifica ter procedimentos e regras corretas em vigor para reduzir rapidamente o impacto de um risco, como uma violação. Conformidade é o método principal usado para desenvolver políticas internas de segurança, requisitos regulatorios e os padrões independentes de uma organização.

Continuidade dos negocios

Capacidade de uma organização manter a produtividade diaria estabelecendo planos de recuperações de riscos e desastres

Segurança de recursos

Focada na proteção de ativos digitais e físicos. Também estando relacionado ao armazenamento, manutenção, retenção e destruição de dados. Significa que ativos com PII ou SPII devem ser manuseados e protegidos com segurança, independentemente. Organizações também precisam ter políticas e procedimentos que garantam que os dados sejam armazenados, mantidos, retidos e destruídos adequadamente.

Como a perda ou o roubo de recursos pode expor uma organização e aumentar o nível de risco, é essencial manter o controle dos recursos e dos dados que eles contêm. A realização de uma análise de impacto na segurança, o estabelecimento de um plano de recuperação de dados e o gerenciamento da exposição ao risco dos dados dependerão do nível de risco associado a cada recurso. Os analistas de segurança talvez precisem armazenar, manter e reter dados criando backups para garantir que sejam capazes de restaurar o ambiente se um incidente de segurança colocar os dados da organização em risco.

Arquitetura e engenharia de Segurança

Focado na otimização da segurança de dados, garantindo a implementação de ferramentas,sistemas e processos eficazes para proteger ativos e dados de uma organização.

Um dos principais conceitos da arquitetura de design segura pe a **responsabilidade compartilhada**

responsabilidade compartilhada - Todos indivíduos em uma organização desempenham um papel ativo na redução de riscos e na manutenção da segurança física e virtual. Com políticas que incentivam os usuários a reconhecer e relatar problemas de segurança, muitos problemas podem ser resolvidos de forma rápida e eficaz. Outros princípios de projeto relacionados a esse domínio, que serão discutidos posteriormente no programa, incluem:

- Modelo de ameaças
- Menor privilégio
- Defesa em profundidade
- Falha segura
- Separação de tarefas
- Manter a simplicidade
- Confiança zero
- Confiar, mas verificar

Um exemplo de gerenciamento de dados é o uso de uma ferramenta de gerenciamento de eventos e informações de segurança (SIEM) para monitorar sinalizadores relacionados a login incomum ou atividade de usuário que possa indicar que um agente de ameaça está tentando acessar dados privados.

Comunicação e a segurança de rede.

Focado principalmente no gerenciamento e na proteção de **redes físicas e comunicações sem fio**. As redes seguras mantêm os dados e as comunicações de uma organização seguros, seja no local, na nuvem ou ao se conectar a serviços remotamente.

As organizações com ambientes de trabalho remoto, híbrido e no local devem garantir que os dados permaneçam seguros, mas o gerenciamento de conexões externas para garantir que os funcionários remotos acessem com segurança as redes de computadores de uma organização é um desafio. A criação de controles de segurança de rede - como acesso restrito à rede - pode ajudar a proteger os usuários e garantir que a rede da organização permaneça segura quando os funcionários viajam ou trabalham fora do escritório principal.

Gerenciamento de identidade e acesso(IAM)

focado no acesso e na autorização para manter os dados seguros, garantindo que os usuários sigam essas políticas estabelecidas para controlar e gerenciar ativos. Basicamente, o objetivo do IAM é reduzir o risco geral para sistemas e dados. Há quatro componentes em IAM:

1. **Identificação**- Usuario verifica quem ele é usando um nome de usuario, cartão de acesso ou dados biometricos;
2. **Autentificação: processo** de verificação para provar a identidade de uma pessoa, como senhas ou pin.
3. **Autorização** - Ocorre após a confirmação da identidade do usuário e está relacionada ao seu nível de acesso, que depende da função na organização.
4. **Accountability(responsabilidade)-** Monitoramento e registro das ações do usuário, com otentativas de login, para provar que os sistemas estão sendo usados adequadamente.

Ele garante que as identidades dos usuários sejam confiáveis e autenticadas e que o acesso aos recursos físicos e lógicos seja autorizado. Isso ajuda a evitar usuários não autorizados e, ao mesmo tempo, permite que os usuários autorizados realizem suas tarefas.

Essencialmente, o IAM usa o que é chamado de princípio de privilégio mínimo, que é o conceito de conceder apenas o acesso e a autorização mínimos necessários para concluir uma tarefa. Por exemplo, um analista de segurança cibernética pode ser solicitado a garantir que os representantes do Atendimento ao Cliente só possam visualizar os dados privados de um cliente, como seu número de telefone, enquanto trabalham para resolver o problema do cliente; em seguida, remova o acesso quando o problema do cliente for resolvido.

Avaliação e teste de Segurança

Foca na realização de testes de controle de segurança, coleta e análise de dados e realização de auditorias de segurança para monitorar riscos, ameaças e vulnerabilidades. Os testes de controles de seguranças podem ajudar uma organização a indentificar novas e melhores maneiras de iticar ameaças, riscos , vulnerabilidades e determinar se seus sistemas internos estão seguros ou em risco .. Isso envolve examinar metas e objetivos organizacionais e avaliar se os controles usados realmente atingem essas metadas, coletar e analisar dados de segurança regulamente também ajuda a evitar ameaças e riscos para a organização.

As organizações podem empregar testadores de penetração, geralmente chamados de "pen testers", para encontrar vulnerabilidades que poderiam ser exploradas por um agente de ameaças.

Esse domínio sugere que as organizações realizem testes de controle de segurança, além de coletar e analisar dados. Além disso, ele enfatiza a importância de realizar auditorias de segurança para monitorar e reduzir a probabilidade de violação de dados. Para contribuir com esses tipos de tarefas, os profissionais de segurança cibernética podem ser encarregados de auditar as permissões dos usuários para validar se eles têm os níveis corretos de acesso aos sistemas internos.

Operações de seguranças

Focadas na condução de investigações e na implementação de medidas preventivas. Investigações começam quando um incidente de segurança é identificado; esse processo exige um pouco mais de senso de urgência para minimizar os riscos potenciais para a organização.

Se houver um ataque ativo, mitigar o ataque e evitar que ele se intensifique ainda mais é essencial para garantir que as informações privadas sejam protegidas dos agentes de ameaça. Após a ameaça neutralizada, coletar evidências digitais e físicas para conduzir uma investigação forense começará.

Uma investigação forense digital deve ocorrer para identificar quando, como e por que a violação ocorreu Isso ajuda na equipe de segurança a determinar areas de melhoria e medida preventiva que podem ser tomadas para mitigar futuros ataques

Isso inclui o uso de estratégias, processos e ferramentas, tais como

- Treinamento e conscientização
- Relatórios e documentação
- Detecção e prevenção de intrusões
- Ferramentas SIEM
- Gerenciamento de registros
- Gerenciamento de incidentes

- Playbooks
- Análise forense pós-violação
- Reflexão sobre as Lições aprendidas

Os profissionais de segurança cibernética envolvidos nesse domínio trabalham em equipe para gerenciar, prevenir e investigar ameaças, riscos e vulnerabilidades. Esses indivíduos são treinados para lidar com ataques ativos, como grandes quantidades de dados sendo acessados da rede interna de uma organização, fora do horário normal de trabalho. Depois que uma ameaça é identificada, a equipe trabalha diligentemente para manter os dados e as informações privadas a salvo dos agentes da ameaça.

Segurança do desenvolvimento de software

focado no uso de práticas seguras de programação. Programação segura é diretriz recomendada usada para criar aplicativos e serviços seguros.

O ciclo de vida de desenvolvimento de software é um processo eficiente usado pelas equipes para criar rapidamente recursos de software. Nesse processo, segurança é uma etapa adicional. A segurança deve ser incorporada a cada elemento do ciclo de vida de desenvolvimento de software (SDLC), desde o projeto e o desenvolvimento até o teste e a liberação. Para obter segurança, o processamento do desenvolvimento de software deve ter a segurança em mente em cada etapa. A segurança não pode ser uma reflexão tardia.

A realização de testes de segurança de aplicativos pode ajudar a garantir que as vulnerabilidades sejam identificadas e mitigadas adequadamente. É necessário ter um sistema para testar as convenções de programação, os executáveis de software e as medidas de segurança incorporadas ao software. Ter profissionais de garantia de qualidade e de teste de caneta para garantir que o software atenda aos padrões de segurança e desempenho também é uma parte essencial do processo de desenvolvimento de software. Por exemplo, um analista de nível básico que trabalha para uma empresa farmacêutica pode ser solicitado a garantir que a criptografia esteja configurada corretamente para um novo dispositivo médico que armazenará dados privados de pacientes.

Ameaças, riscos e vulnerabilidades

Ameaças

Qualquer circunstância ou evento que possa impactar negativamente os ativos. Como analista de segurança de nível básico, seu trabalho é ajudar a defender os recursos da organização contra ameaças internas e externas. Portanto, compreender os tipos comuns de ameaças é importante para o trabalho diário de um analista. Para relembrar, as ameaças comuns incluem:

- **Ameaças internas:** Membros da equipe ou Fornecedores abusam de seu acesso autorizado para obter dados que podem prejudicar a organização.
- **Ameaças persistentes avançadas (APTs):** Um agente de ameaça mantém o acesso não autorizado a um sistema por um longo período de tempo.

ex: **engenharia social** - tecnica de manipulação que explora o erro humano para obter infos privadas, acesso ou objetos de valor. como:Phishing

Riscos

Qualquer coisa coisa que possa afetar a integridade, confidencialidade e disponibilidade de um recurso(ativo).

ex: falta de protocolos de backups para garantir que infos armazenadas possam ser recuperadas. Como analista de segurança de nível básico, seu trabalho é ajudar a defender os recursos da organização contra ameaças internas e externas. Portanto, compreender os tipos comuns de ameaças é importante para o trabalho diário de um analista. Para relembrar, as ameaças comuns incluem:

- **Ameaças internas:** Membros da equipe ou Fornecedores abusam de seu acesso autorizado para obter dados que podem prejudicar a organização.
- **Ameaças persistentes avançadas (APTs):** Um agente de ameaça mantém o acesso não autorizado a um sistema por um longo período de tempo.

As organizações tendem a classificar riscos em niveis diferentes: baixo, medio e alto risco. Dependendo das possiveis ameaças e do valor de um recurso.

Ameaça de baixo risco: É uma informação que não prejudicaria a reputação ou operações em andamneto da organização e não causariam danos financeiros se comprometidas.

Ameaça de medio risco: Informação que não esta disponivel ao publico e podem causas algum danos à finanças, à reputação ou a operações em andamento.

Ameaça de alto risco: Informações protegidas por regulações e leis, a qual se comprometida tendem a ter impactos severos e negativos a finanças, operações em andamento ou reputação da empresa;

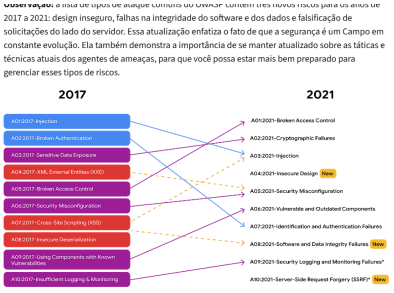
Há muitos recursos, como o NIST, que fornecem listas de

riscos de segurança cibernética

. Além disso, o Projeto de Segurança de Aplicativos da Web Aberta (OWASP) publica um documento de conscientização padrão sobre os

10 principais riscos de segurança mais críticos

para aplicativos da Web, que é atualizado regularmente.



Vulnerabilidade

É uma fraqueza que pode ser explorada por uma ameaça. Portanto, as organizações precisam inspecionar regularmente as vulnerabilidades em seus sistemas. Algumas vulnerabilidades incluem:

- **ProxyLogon:** Uma vulnerabilidade pré-autenticada que afeta o servidor Microsoft Exchange. Isso significa que um agente de ameaça pode concluir um processamento de autenticação de usuário para implantar um código malicioso de um local remoto.
- **ZeroLogon:** Uma vulnerabilidade no protocolo de autenticação Netlogon da Microsoft. Um protocolo de autenticação é uma forma de verificar a identidade de uma pessoa. O Netlogon é um serviço que garante a identidade de um usuário antes de permitir o acesso ao local de um site.
- **Log4Shell:** Permite que os atacantes executem programação Java no computador de outra pessoa ou vazem informações confidenciais. Ele faz isso permitindo que um ataque remoto assuma o controle de dispositivos conectados à Internet e execute códigos maliciosos.
- **PetitPotam:** Afeta o NTLM (New Technology Local Area Rede) Manager (Gerenciador de rede local) do Windows. É uma técnica de roubo que permite que um ataque baseado em LAN inicie uma solicitação de autenticação.
- **Falhas na geração de registros e monitoramento de segurança:** Recursos insuficientes de geração de registros e monitoramento que fazem com que os atacantes explorem vulnerabilidades sem que a organização saiba
- **Falsificação de solicitação no lado do servidor:** Acessível para que os atacantes manipulem um aplicativo do lado do servidor para acessar e atualizar recursos de backend. Também pode permitir que os agentes de ameaças roubem dados.

Como analista de segurança de nível básico, você pode trabalhar no gerenciamento de vulnerabilidades, que é o monitoramento de um sistema para identificar e mitigar vulnerabilidades. Embora possam existir patches e atualizações, se eles não forem aplicados, ainda podem ocorrer intrusões. Por esse motivo, o monitoramento

constante é importante. Quanto mais cedo uma organização identificar uma vulnerabilidade e abordá-la aplicando patches ou atualizando seus sistemas, mais cedo ela poderá ser mitigada, reduzindo a exposição da organização à vulnerabilidade.

Para saber mais sobre as vulnerabilidades explicadas nesta seção de leitura, bem como sobre outras vulnerabilidades, explore o Banco de Dados de Vulnerabilidades Nacionais do NIST e o Catálogo de Vulnerabilidades Exploradas Conhecidas da CISA.

Ransomware

É um ataque malicioso que garantem que os agentes de ameaças criptografem os dados de uma organização e exigem pagamento para restaurar o acesso.

Camadas da internet

- **Surface web** - camada que a maioria das pessoas usa. COntem conteudos que podem ser usados em um navegador da web
- **Deep web**- Geralmente requer autorização para acessá-la. A intranet de uma organização é um exemplo de deepweb
- **Dark Web** - Só pode ser acessada usando um software especial. Normalmente tem uma conotaão negativa, pois criminosos a usam devido ao sigilo que fornece;

Principais impactos de ameaças, riscos e vulnerabilidades.

- impacto financeiros
- roubo de identidade
- Dano à reputação de uma organização
-

Gerenciamento de riscos do NIST

O instituto Nacional de Padrões e tecnologia, NIST, fornecem estruturas que são usadas por profissionais de seguranças para gerenciar riscos. exemplo a RMF.

Na Risk Management Framework(RMF) há sete etapas: **preparar, categorizar,selecionar, implementar,avaliar, autorizar e monitorar.**

- **RMF passo 1: preparação** - Atividades que são necessarias para gerenciar riscos de segurança e privacidade antes que uma violação ocorra.
- **RMF passo 2: categorizar** - Usada para desenvolver processos e tarefas de gerenciamento de riscos. Profissionais de segurança usam esse processo para desenvolver tarefas pensando em como a confidencialidade, a integridade e a disponibilidade dos sistemas e das informações podem ser afetadas pelo risco.
- **RMF passo 3: selecionar -** selecionar significa escolher, personalizar e capturar a documentação dos controles que protegem uma organização. Exemplo: manter um manual atualizado ou ajudar a gerenciar outra documentação que permita que você e sua equipe resolvam problemas com mais eficiencias.
- **RMF passo 4: implementar -** Implementar planos de seguranças e privacidades para a organização.
- **RMF passo 5: Avaliar -** Avaliar se meios de controles estabelecidos estão implementados corretamentes.
- **RMF passo 6: Autorizar -** Ser responsavel pelos riscos de segurança e privacidades que possam existir em uma organização
- **RMF passo 7: Monitorar -** Ser consciente de como os sistemas estão operando.

Gerenciamento de riscos

Um dos principais objetivos das organizações é proteger os recursos. Um **recurso** é um item percebido como tendo valor para uma organização. Os recursos podem ser digitais ou físicos. Exemplos de recursos digitais incluem as informações pessoais de funcionários, clientes ou Fornecedores, tais como

- Números de Seguro Social (SSNs) ou números de identificação nacional únicos atribuídos a indivíduos
- Datas de nascimento
- Números de contas bancárias
- Endereços de correspondência

Exemplos de recursos físicos incluem:

- Quiosques de pagamento
- Servidores
- Computadores de mesa
- Espaços de escritório

Algumas estratégias comuns usadas para gerenciar riscos incluem:

- **Aceitação**: Aceitar um Risco para evitar a interrupção da continuidade dos negócios
- **Evitar**: Criação de um planejamento para evitar totalmente o risco
- **Transferência**: Transferir o risco para um terceiro gerenciar
- **Mitigação**: Diminuição do impacto de um risco conhecido

Além disso, as organizações implementam processos de gerenciamento de riscos com base em frameworks amplamente aceitos para ajudar a proteger os recursos digitais e físicos de várias ameaças, riscos e vulnerabilidades. Exemplos de frameworks comumente usados no setor de segurança cibernética incluem o National Institute of Standards and Technology Risco Management Framework(NIST RMF) e a Health Informações Trust Alliance(HITRUST).

Seguem alguns tipos comuns de ameaças, riscos e vulnerabilidades que você ajudará as organizações a gerenciar como profissional de segurança.

Modulo 2: Frameworks e controle de segurança

Organizações usam security frameworks para fazerem suas proprias politicas e processo.

Security frameworks

São diretrizes usadas para **criar planos e ajudar a mitigar riscos e ameaças aos dados e privacidade dos dados.** As frameworks apoiam a capacidade das organizações de aderir às leis e aos regulamentos de conformidade. A segurança envolve mas do que o espaço virtual, também incluindo o fisico.

As frameworks podem serem usadas para criar planos que aumentem a conscientização dos funicionários e os eduquem sobre como eles podem proteger a organização, colegas de trabalhos ou a si mesmos.

Framework de Ameaça Cibernética (CTF)

De acordo com o Escritório do Diretor de Inteligência Nacional, o CTF foi desenvolvido pelo governo dos EUA para fornecer "uma linguagem comum para descrever e comunicar informações sobre a atividade de ameaças cibernéticas" Ao fornecer uma linguagem comum para comunicar informações sobre a atividade de ameaças, o CTF ajuda os profissionais de segurança cibernética a analisar e compartilhar informações com mais eficiência. Isso permite que as organizações melhorem sua resposta ao cenário de segurança cibernética em constante evolução e às diversas táticas e técnicas dos agentes de ameaças.

Organização Internacional de Padronização/Comissão Eletrotécnica Internacional (ISO/IEC) 27001

Um framework internacionalmente reconhecido e usado é o ISO/IEC 27001. A família de padrões ISO 27000 permite que organizações de todos os setores e tamanhos gerenciem a segurança de recursos, como informações financeiras, propriedade intelectual, dados de funcionários e informações confiadas a terceiros. Essa framework descreve os requisitos de um sistema de gerenciamento de segurança da informação, as práticas recomendadas e os controles que apoiam a capacidade da organização de gerenciar riscos. Embora a framework ISO/IEC 27001 não exija o uso de controles específicos, ela fornece um conjunto de controles que as organizações podem usar para melhorar sua postura de segurança.

Controles

Controles de segurança **são proteções projetadas para reduzir riscos de segurança especificos .**São usados para reduzir riscos especifícos. Se os controles adequados não estiverem em vigor, a organização pode enfrentar impactos financeiros significativos e danos à reputação

Os controles podem ser físicos, técnicos e administrativos e, normalmente, são usados para prevenir, detectar ou corrigir problemas de segurança.

Exemplos de controles físicos:

- Portões, cercas e travas
- Guardas de segurança
- Circuito fechado de televisão (CCTV), câmeras de vigilância e detectores de movimento
- Cartões de acesso ou crachás para entrar em espaços de escritórios

Exemplos de controles técnicos:

- Firewalls
- MFA
- Software antivírus

Exemplos de controles administrativos:

- Separação de tarefas
- Autorização
- Classificação de recursos
-

Tipos de controles:

Cryptografia(Encryption) -

Processo de conversão de dados de um formato legível para um formato codificado. Basicamente transformar dados em um texto criptografado, texto criptografado é uma mensagem bruta e codificada que é ilegivel para humanos e computadores.

Dados de texto criptografados não podem ser lidos até seresm descriptografados em sua forma original de texto sem formatação. A criptografia é **usada para manter confidencialidade de dados conficenciais**, como info. de contas de clientes ou numeros de previdencias sociais

Autentificação

Processo de verificar quem é alguem ou alguma coisa. Um exemplo é aa geração de registros de um site com nome e senha, para provar que você sabe o nome de usuario e a senha e assim voce tem a permição para acessar o site.

Metodos mais avançados de autentificação como: multifatorial ou MFA exigem uma forma adicional de autentificação, como um cofigo de segurança ou biometria...

A Biometria é uma **caracteristica única que pode ser usada para verificar a indentidade de uma pessoa**. ex: impressão digital, exame ocular ou escaneamento da palma da mão.

Um exemplo de engenharia social que podem explorar dados biometricos é o **Vishing:** exploração da comunicação eletronica de voz para obter infs confidenciais ou se passar por uma fonte conhecida

Autorização

Se refere ao conceito de conceder acesso a recursos especificos dentro de um sistema. Essencialmente a autorização é usada para **verificar se uma pessoa tem permissão para acessar um recurso**

Triade CIA

A triade da CIA(confidencialidade, integridade e disponibilidade) é **um modelo central de segurança que ajudará a informar como as organizações consideram risco ao configurar sistemas e politicas de segurança;** Manter um nível aceitável de risco e garantir que os sistemas e as políticas sejam projetados com esses elementos em mente ajuda a estabelecer uma **postura de segurança** bem-sucedida, que se refere à capacidade de uma organização de gerenciar a defesa de recursos e dados críticos e reagir a mudanças.

Confidencialidade

Apenas usuarios autorizados podem acessar ativos ou dados especificos. Dados confidenciais devem estar disponiveis com base na "necessidade de conhecimento", para que somente pessoas autorizadas a lidar com esses determinados ativos ou dados tenham acesso. Em uma organização, a confidencialidade pode ser aprimorada por meio da implementação de princípios de design, como o princípio do privilégio mínimo. O princípio do privilégio mínimo limita o acesso dos usuários apenas às informações necessárias para realizar tarefas relacionadas ao trabalho. Limitar o acesso é uma forma de manter a confidencialidade e a segurança dos dados privados.

Integridade

Dados estão corretos, autênticos e confiaveis. Determinar integridade dos dados e analisar como eles são ajudará a decidir se os dados podem ou não ser confiaveis. Uma maneira de verificar a Integridade dos dados é por meio da criptografia, que é usada para transformar os dados de modo que partes não autorizadas não possam lê-los ou adulterá-los (NIST, 2022). Outro exemplo de como uma organização pode implementar a integridade é ativar a criptografia, que é o processamento da conversão de dados de um formato legível em um formato codificado. A criptografia pode ser usada para impedir o acesso e garantir que os dados, como mensagens na plataforma de bate-papo interna de uma organização, não possam ser adulterados.

Disponibilidade

Dados estão acessiveis para aqueles que estaão autorizados a acessa-los. Dados inacessiveis não são uteis e podem impedir que pessoas possam realizar se trabalho. Quando um sistema adere aos princípios de disponibilidade e confidencialidade, os dados podem ser usados quando necessário. No local de trabalho, isso pode significar que a organização permite que funcionários remotos acessem sua rede interna para realizar seus trabalhos. É importante observar que o acesso aos dados na rede interna ainda é LIMIT, dependendo do tipo de acesso que os funcionários precisam para realizar seu trabalho. Se, por exemplo, um funcionário trabalha no departamento de contabilização da organização, ele pode precisar de acesso a contas corporativas, mas não a dados relacionados a projetos de desenvolvimento em andamento.

Frameworks do NIST

NIST cybersecurity Framework(CSF)

Framework voluntaria que consiste em padrões, diretrizes e boas praticas para gerenciar riscos de cyber segurança. Essa framework é altamente respeitada e essencial para menter a segurança. O csf consiste em 5 funções principais: **governar, identificar proteger,detectar, responder e recuperar.**

O csf pode ser usado para proteger contra ameaças,riscos e vulnerabilidades. Fornecem orientações especificas para profissionais de seguranças e também é **usado para desenvolver plano para lidar com um incidenter de forma adequada e rapida e reduzir riscos, proteger contra ameaças e mitigar qualquer possivel vulnerabilidade**

principais funções do cfs:

Indentificar

Esta relacionado ao gerenciamento de riscos de segurança cibernetica e e seu efeito nos ativos e pessoas da organização.

Proteger

Estrategia usada para proteger uma organização por meio de implementações de politicas, procedimentos, treinamentos e ferramentas que ajugam a mitigar ameaças à cyber segurança

Detectar

Idenficar potencias incidentes de seguranças e melhorar a recursos de monitoramento para aumentar a velocidade e a eficiência das detecções

Respond(responder)

Ter certeza que o procedimento apropriados sejam usados paraa conter, neutralizar e analisar incidentes de segurança e implementar melhoras para o processo de segurança

Recover

Processo de devolver sistemas afetados à operação normal

NIST S.P 800-53

Framework unificada para proteger a segurança dos sistemas de infos dentro do governo dos eua.

Principios da segurança da OWASP

Open Web Applications security Project(OWASP)

- **Minimizar a superficie de ataque**- **A superficie de ataque se refere a todas vulnerabilidades potenciais que um agente de ameaça possa explorar**, Como vetores de ataque(caminhos que os atacantes podem usar para penetrar nas defesas de segurança, como phishing e senhas fracas). Para minimizar tal superficie de ataque e evitar acidente desses vetores, as equipes de segurança podem desativar recursos de software, restringir acessos a determinados acessos ou estabelecer requisitos de senhas mais complexos

- **Principio do privilegio minimo** - Garantir que **usuarios tenham a menor quantidade de acesso nescessaria para realizar suas tarefas diarias**. O principal motivo para limitar o acesso às informações e recursos é reduzir a quantidade de danos que uma violação de segurança pode causar.
- **Defesa em profundidade** - Significa que uma **organização deve ter vários controles de segurança que abordem riscos e ameaças de maneiras diferentes**. Ex: Autentificação multifator (exige que os usuários dêem mais um passo além de simplesmente digitar seu nome de usuário e senha para obter acesso). Outros controles incluem firewalls , sistemas de detecção de intrusão e configurações de permissão que podem ser usadas para criar vários pontos de defesa, pelos quais um agente de ameaças deve passar para violar uma organização.
- **Separar Funções** - **As ações críticas devem depender de várias pessoas, cada uma das quais deve seguir o princípio do privilégio mínimo**. Ninguem deve ter tantos privilegios que possa usar indevidamente o sistema. Ex. A pessoa que assina contra-cheques, não pode ser a mesma que os preparam. Isso pode impedir que individuos realizem atividades fradulentas/ilegais.
- **Manter a segurança simples-** Ao implementar a seguranças, **procedimentos desnecessariamente complicados devem ser evitados**, pois podem se tornar incontrolaveis. Quanto mais complexos são os sistemas, masi dificeis serão para as pessoas trabalharam nele de forma corporativa.
- **Corrigir os problemas de seguranças corretamente** - Quando ocorre um incidente de segurança, espera-se que os profissionais de segurança **identifiquem a causa raiz rapidamente**. A partir daí, é importante c**orrigir todas as vulnerabilidades identificadas e realizar testes para garantir que os reparos sejam bem-sucedidos.** Um exemplo de problema é uma senha fraca para acessar o wifi de uma organização , pois isso pode levar a

uma violação. Para corrigir esse tipo de problema de segurança, políticas de senha mais rígidas podem ser implementadas.

Principios adicionais de Seguranças da OWASP:

- **Estabelecer padrões seguros -** Esse princípio significa que o estado de **segurança ideal de um aplicativo também é o estado padrão para os usuário**s; deve ser necessário um trabalho extra para tornar o aplicativo inseguro.
- **Falhar com segurança -** Falhar com segurança significa que, quando um **controle falha ou é interrompido, ele deve fazer isso usando como padrão a sua opção mais segura**. Por exemplo, quando um firewall falha, ele deve simplesmente fechar todas as conexões e bloquear todas as novas, em vez de começar a aceitar tudo.
- **Não confie nos serviços -** Muitas organizações trabalham com parceiros terceirizados. Esses parceiros externos geralmente têm políticas de segurança diferentes das da organização. E a **organização não deve confiar explicitamente que os sistemas de seus parceiros são seguros**. Por exemplo, se um fornecedor terceirizado rastreia pontos de recompensa para clientes de companhias aéreas, a companhia aérea deve garantir que o saldo seja preciso antes de compartilhar essas informações com seus clientes.
- **Evite a segurança por obscuridade - A segurança dos principais sistemas não deve se basear em manter os detalhes ocultos**. Considere o seguinte exemplo da OWASP (2016): OWASP Mobile Top 10. A segurança de um aplicativo não deve depender da manutenção do código-fonte em segredo. Sua segurança deve depender de muitos outros fatores, incluindo políticas de senha razoáveis, defesa em profundidade, limites de transações comerciais, Arquitetura de rede sólida e controles de fraude e auditoria.

Planeje uma auditoria de Segurança

Auditoria de Segurança

É a revisão dos controles , políticas e procedimentos de segurança de uma organização em relação a um conjunto de expectativas. Existem dois tipos principais de auditorias de segurança: **externas e internas**.

Os critérios internos incluem políticas, procedimentos e práticas recomendadas delineadas. Os critérios externos incluem conformidade regulatória, leis e normas federais.

Além disso, uma auditoria de segurança pode ser usada para avaliar os controles de segurança estabelecidos por uma organização. AS, **os controles de segurança** são salvaguardas projetadas para reduzir riscos de segurança específicos.

As auditorias ajudam a garantir que sejam feitas verificações de segurança (ou seja, monitoramento diário de painéis de gerenciamento de eventos e informações de segurança) para identificar ameaças, riscos e vulnerabilidades. Isso ajuda a manter a postura de segurança de uma organização. E, se houver problemas de segurança, um processamento de correção deve estar em vigor.

- Uma **auditoria interna** de segurança geralmente é conduzida por uma equipe de pessoas que pode incluir o oficial de conformidade da organização, o gerente de segurança e outros membros da equipe de segurança. As auditorias internas de segurança são usadas para ajudar a melhorar a postura de segurança de uma organização e ajudar as organizações a evitar multas de agências governamentais devido à falta de conformidade.

Objetivos e metas de uma auditoria

A meta de uma auditoria é garantir que as práticas de tecnologia da informação (TI) de uma organização atendam aos padrões organizacionais e do setor. O Objetivo é identificar e abordar áreas de correção e crescimento. As auditorias fornecem orientação e clareza, identificando quais são as falhas atuais e desenvolvendo um plano para corrigi-las.

As auditorias de segurança devem ser realizadas para proteger os dados e evitar penalidades e multas de agências governamentais. A Frequência das auditorias depende das leis locais e dos Regulamentos Federais de Conformidade.

- Identificar riscos organizacionais
- Avaliar controles

- Corrigir problemas de conformidade;

Fatores que afetam as auditorias

Os fatores que determinam os tipos de auditorias que uma organização implementa incluem:

- Tipo de setor
- Tamanho da organização
- Vínculos com as regulamentações governamentais aplicáveis
- A localização geográfica de uma empresa
- Uma decisão comercial de aderir a uma conformidade regulatória específica

Função das estruturas e controles nas auditorias

Juntamente com a conformidade, é importante mencionar a função das estruturas e dos controles nas auditorias de segurança. Estruturas como a National Institute of Standards and Technology Cybersecurity Framework (NIST CSF) e a série de normas internacionais de segurança da informação (ISO 27000) foram criadas para ajudar as organizações a se prepararem para auditorias de segurança de conformidade regulamentar. Ao aderir a essas e outras frameworks relevantes, as organizações podem economizar tempo ao realizar auditorias externas e internas. Além disso, as frameworks, quando usadas juntamente com os controles, podem apoiar a capacidade das organizações de se alinharem aos Requisitos e padrões de conformidade regulamentar.

Há três categorias principais de controles a serem analisados durante uma auditoria, que são os controles administrativos e/ou gerenciais, técnicos e físicos.
https://docs.google.com/document/d/1Ut_H5A9FHwuQEy6_qG6Lfy3zwF6GSJnj3DZTMaNRWEE/template/preview?resourcekey=0-i4dR5qZFqQyfzr8uk3OOmA

Elementos comuns de uma Auditoria

- Estabelecer escopos e objetivos;
- Conduzir uma avaliação de riscos dos ativos da organização;
- Concluir uma avaliação de controles;
- Avaliar a conformidade;
- COmunicar resultados às partes interessadas;

- **Estabelecer escopos e objetivos**- Escopos se refere aos criterios especificos de uma auditoria interna de segurança. O escopo exige que as organizações identifiquem pessoas, ativos , políticas, procedimentos e tecnologias que possam afetar a postura de segurança de uma organização. As **metas** são um esboço dos objetivos de segurança da organização ou **do que ela deseja alcançar para melhorar sua postura de segurança**.

A auditoria deve:

- Listar os recursos que serão avaliados (por exemplo, se os firewalls estão configurados corretamente, se os PII estão seguros, se os recursos físicos estão trancados etc.)
- Observar como a auditoria ajudará a organização a atingir seus objetivos desejados
- Indicar a frequência com que a auditoria deve ser realizada
- Inclua uma Avaliação das políticas, protocolos e procedimentos organizacionais para garantir que estejam funcionando como pretendido e sendo implementados pelos funcionários

- **Conduzir uma avaliação de riscos dos ativos da organização-** Realizar uma avaliação de risco , focada na identificação de possíveis ameaças, riscos e vulnerabilidades. Isso ajuda as organizações a considerar quais medidas de segurança devem ser implementadas e monitoradas para garantir a segurança dos ativos. Semelhante ao estabelecimento do escopo e das metas, uma avaliação de risco geralmente é concluída por gerentes ou outras partes interessadas. No entanto, talvez você precise analisar os detalhes fornecidos na

avaliação de risco para considerar quais tipos de controles e regulamentações de conformidade precisam estar em vigor para ajudar a melhorar a postura de segurança da organização

Faça perguntas sobre a auditoria :

1. O que a auditoria pretende alcançar?
2. Quais ativos estão em maior risco?
3. Nossos controles atuais são suficientes para a proteção desse ativo? Se não, quais controles e regulamentações de conformidades precisam ser implementados?

- **Concluir uma avaliação de controles**- Envolve analisar de perto os ativos existentes de uma organização e, em seguida, avaliar riscos em potenciais para esses ativos para garantir que os controles e processos internos sejam eficazes.

  Categorias de controles

  - **Controles administrativos**: Estão relacionados ao componente humano da cybersegurança, incluido politicas e procedimentos que definem como uma organização gerencia dados, como implementação de politicas de senha
  - **Controles tecnicos:** Soluções de Hardwares e Softwares usadas para proteger ativos como o uso de sistemas de detecção de intrusão, ou IDS, e criptografia.
  - **Controles fisicos:** Medidas implementadas para impedir acesso fisico a ativos protegidos, como câmeras de vigilância e fechaduras;
- **Avaliar a conformidade** - Os regulamentos de conformidade são leis que as organizações devem seguir para garantir que os dados privados permaneçam seguros.

- Comunicar resultados às partes interessadas - Depois que a auditoria interna de segurança for concluida, os resultados e recomendações devem ser comunicados às partes interessadas.

MODULO 3: Introdução a Ferramentas de ciber seguranças

Log

É um registro de eventos que ocorreram nos sistemas e redes de uma organização.

Tipos de logs comuns:

- **Logs de firewall** - É um registro de conexões tentadas ou estabelecidas para o tráfego de entrada internet. Isso inclui saida da internet para dentro da rede
- **Logs de rede** - Gravação de todos os computadores e dispositivos que entram e saem da rede. Ele registra conexões entre dispositivos e serviços na rede
- **Logs dos servidores** - É um registro dos eventos relacionados a serviços como sites, e-mails ou compartilhamento de arquivos. Incluindo ações como loguin, senhas e nome de usuario

Security information and event management(SIEM)

Um aplicativo que coleta e analisa dados de registro para monitorar atividades criticas em uma organização. As ferramentas SIEM oferecem monitoramento e acompanhamento em tempo real de registros de eventos de segurança. Os dados são usados para realizar uma análise completa de qualquer ameaça potencial à segurança, risco ou vulnerabilidade identificados .As ferramentas de SIEM também podem ser usadas para criar painéis, eles apresentam informações sobre sua conta ou localização em um formato fácil de entender.

Painéis

Os painéis do SIEM ajudam os analistas de segurança a acessar de forma rápida e fácil as informações de segurança de sua organização na forma de tabelas, gráficos ou tabelas. Usando um painel, o analista de segurança conseguiu analisar rapidamente as representações visuais da linha do tempo das tentativas de login, da

localização e da hora exata da atividade e, em seguida, determinar se a atividade era suspeita. Além de fornecer um resumo abrangente dos dados relacionados à segurança, os painéis do SIEM também fornecem às partes interessadas métricas diferentes.

Metricas

São atributos tecnicos fundamentais, como tempo de resposta, disponibilidade e taxas de falhas, que são usados para avaliar o desempenho de um app de software. Os painéis do SIEM podem ser personalizados para exibir métricas específicas ou outros dados relevantes para diferentes membros de uma organização

Futuro da SIEM

Como a segurança cibernética continua a evoluir, a necessidade de funcionalidade em Nuvem aumentou. As ferramentas SIEM evoluíram e continuam evoluindo para funcionar em ambientes hospedados na nuvem e nativos da nuvem. As ferramentas SIEM hospedadas na nuvem são operadas por Fornecedores que são responsáveis por manter e gerenciar a infraestrutura necessária para usar as ferramentas. As ferramentas hospedadas na Nuvem são simplesmente acessadas pela Internet e são uma solução ideal para organizações que não querem investir na criação e manutenção de sua própria infraestrutura.

Acessível às ferramentas SIEM hospedadas na nuvem, as ferramentas SIEM nativas da nuvem também são totalmente mantidas e gerenciadas pelos Fornecedores e acessadas pela Internet. No entanto, as ferramentas nativas da nuvem são projetadas para aproveitar ao máximo os recursos de computação em nuvem, como disponibilidade, flexibilidade e escalonabilidade.

Ainda assim, espera-se que a evolução das ferramentas SIEM continue a fim de acomodar a natureza mutável da tecnologia, bem como as novas táticas e técnicas dos agentes de ameaças.

A implementação da automação também ajudará as equipes de segurança a responder mais rapidamente a possíveis incidentes, realizando muitas ações sem esperar por uma resposta humana. A **orquestração, automação e resposta de segurança (SOAR)** é um conjunto de aplicativos, ferramentas e Fluxos de trabalho que usa a automação para responder a eventos de segurança. Essencialmente, isso significa que o processamento de incidentes comuns relacionados à segurança com o uso de ferramentas SIEM deverá se tornar um processo mais simplificado, exigindo menos intervenção manual.

Diferentes tipos de ferramentas SIEM

- **Auto-hospedada**: Exigem que a organização instalem, operem e mantenham a ferramenta usando a propria infraestrutura fisica, como a capacidade do servidor. São providos e mantidos pelo departamento de TI da organização. Ideais quando a **organização precisa manter controle fisico sobre dados confidenciais.**
- **Hospedada na nuvem:** Mantidas pelos provedores de SIem, tornando-as acessiveis pela internet. Ideais para organizações que **não querem investir na criação e manutenção de infraestrutura**
- Hibrida: Combinação de auto-hospedada e de hospedagem nuvem, podendo aproveitar o beneficio da nuvem e manter o controle fisico de seus dados confidenciais.

Ferramentas SIEM

O Splunk Enterprise, o Splunk Cloud e o Chronicle são ferramentas SIEM comuns que muitas organizações usam para ajudar a proteger seus dados e sistemas

Splunk

Plataforma de analise de dados e a **Splunk Enterprise** fornece soluções de SIEM

Splunk Enterprise

É uma ferramenta **auto-hospedada** usada para reter, analisar e pesquisar os dados de registros de uma organização para fornecer informações e alertas de segurança em tempo real.

Splunk Cloud

Uma ferramenta hospedada na nuvem para coletar, pesquisar e monitorar dados de registro. Ideal para ambientes hibridos ou de nuvens.

Chronicle

Uam ferramenta **nativa** na nuvem projetada para reter,analisar e pesquisar dados.

Assim como as ferramentas hospedadas na nuvem, as ferramentas nativas da nuvem também são totalmente mantidas e gerenciadas pelo fornecedor. Mas as **ferramentas nativas da nuvem são projetadas especificamente para aproveitar ao máximo os recursos de computação em nuvem, como disponibilidade , flexibilidade e escalonabilidade.** j

Ferramentas de código aberto

As ferramentas de código aberto geralmente são de uso gratuito e podem ser fáceis de usar. O objetivo das ferramentas de código aberto é fornecer aos usuários um software criado pelo público de forma colaborativa, o que pode fazer com que o software seja mais seguro e permitem maior personalização pelos usuários, resultando em uma variedade de novos serviços criados a partir do mesmo pacote de software de código aberto.

Os engenheiros de software criam projetos de código aberto para aprimorar o software e torná-lo disponível para uso de qualquer pessoa, desde que a licença especificada seja respeitada. Ter essas fontes prontamente disponíveis permite que os usuários modifiquem e aprimorem os materiais do projeto.

Ferramentas proprietárias

As ferramentas proprietárias são desenvolvidas e pertencem a uma pessoa ou empresa, e os usuários geralmente pagam uma taxa pelo uso e pelo treinamento. Os proprietários das ferramentas proprietárias são os únicos que podem acessar e modificar o código-fonte. Isso significa que os usuários geralmente precisam esperar que sejam feitas atualizações no software e, às vezes, podem precisar pagar uma taxa por essas atualizações. O software proprietário geralmente permite que os usuários modifiquem um número LIMIT de recursos para atender às necessidades individuais e organizacionais. Exemplos de ferramentas proprietárias incluem as ferramentas SIEM Splunk® e Google SecOps (Chronicle).

Equívocos comuns

Há uma concepção errônea comum de que as ferramentas de código aberto são menos eficazes e não são tão seguras de usar quanto as ferramentas proprietárias. No entanto, os desenvolvedores vêm criando materiais de código aberto há anos que se tornaram padrões do setor. Embora seja verdade que os agentes de ameaças tenham tentado manipular as ferramentas de código aberto, como essas ferramentas são de código aberto, é realmente mais difícil para as pessoas mal-intencionadas causarem danos com sucesso. A ampla exposição e o acesso imediato ao código-fonte por usuários e profissionais bem-intencionados e informados tornam menos provável a ocorrência de problemas, pois eles podem corrigi-los assim que forem identificados.

Exemplos de ferramentas de código aberto

Em segurança, há muitas ferramentas em uso que são de código aberto e comumente disponíveis. Dois exemplos são o Linux e o Suricata.

Linux

O Linux é um sistema operacional de código aberto amplamente utilizado. Ele permite que você adapte o sistema operacional às suas necessidades usando uma interface de Linha de Comando (CLI). Um **sistema operacional** é a interface entre o hardware do computador e o usuário. É usado para se comunicar com o hardware de um computador e gerenciar aplicativos de software.

Há várias versões do Linux que existem para realizar tarefas específicas. O Linux e sua interface de Linha de Comando (CLI) serão discutidos em detalhes posteriormente no programa de certificação.

Suricata

O Suricata é um software de código aberto de análise de rede e detecção de ameaças, usado para inspecionar o tráfego de rede a fim de identificar comportamentos suspeitos e gerar registros de dados da rede. O software de detecção encontra atividades entre usuários, computadores ou endereços IP (Protocolo de Internet) para ajudar a descobrir possíveis ameaças, riscos ou vulnerabilidades.

O Suricata foi desenvolvido pela Open Information Security Foundation (OISF). A OISF se dedica a manter o uso do código aberto do projeto Suricata para garantir que ele seja gratuito e esteja disponível ao público. A Suricata é amplamente utilizada nos setores público e privado e se integra a muitas ferramentas SIEM e outras ferramentas de segurança. O Suricata também será discutido em mais detalhes posteriormente no programa.

Splunk e Chronicle (Ferramentas SIEM)

O texto descreve duas ferramentas de Gerenciamento de Informações e Eventos de Segurança (**SIEM**): **Splunk** (com as opções Enterprise e Nuvem) e **Chronicle** (do Google, nativa da nuvem). Ambas as ferramentas ajudam profissionais de segurança a monitorar, analisar e gerenciar a infraestrutura de TI de uma organização, coletando dados de registros de várias fontes e exibindo-os em **Painéis** (Dashboards).

Painéis do Splunk

O Splunk fornece painéis focados em diferentes aspectos da segurança:

- **Painel de Postura de Segurança (Security Posture):** Para Centros de Operações de Segurança (**SOC**). Exibe eventos e tendências de segurança das últimas 24 horas, ajudando a monitorar e investigar ameaças em tempo real (ex.: atividade de rede suspeita).
- **Painel de Resumo Executivo (Executive Summary):** Analisa e monitora a saúde geral da segurança ao longo do tempo. Ajuda a fornecer *insights* de alto nível para as partes interessadas, resumindo incidentes e tendências.
- **Painel de Revisão de Incidentes (Incident Review):** Permite identificar padrões suspeitos e destacar itens de **alto risco** que exigem atenção imediata, fornecendo uma linha do tempo visual dos eventos que levaram a um incidente.
- **Painel de Análise de Risco (Risk Analysis):** Ajuda a identificar o risco para cada objeto (usuário, computador, IP) e mostra mudanças em atividades ou comportamentos de risco (ex.: login fora do horário). Auxilia na priorização dos esforços de mitigação de riscos.

Painéis do Chronicle

O Chronicle, um SIEM nativo da nuvem, também oferece vários painéis para monitoramento e análise de logs com foco em recursos, domínios, usuários e IPs:

- **Painel de Insights da Empresa (Enterprise Insights):** Destaca **alertas recentes** e identifica domínios suspeitos (**IOCs** - Indicadores de Comprometimento), indicando a probabilidade da ameaça (pontuação de confiança) e a importância (nível de gravidade).
- **Painel de Ingestão e Integridade de Dados (Data Ingestion and Health):** Mostra estatísticas sobre o processamento de dados (eventos, gerações de logs, taxas de sucesso), ajudando a garantir que as fontes de log estejam configuradas corretamente e livres de erros.
- **Painel de Correspondências de IOC (IOC Match):** Indica as principais ameaças, riscos e vulnerabilidades, permitindo observar tendências em IOCs, IPs e domínios ao longo do tempo para direcionar o foco da equipe.
- **Painel Principal (Main):** Apresenta um resumo de alto nível sobre ingestão de dados, alertas e atividade de eventos, permitindo identificar tendências de ameaças.
- **Painel de Detecções de Regras (Rule Detections):** Fornece estatísticas sobre incidentes (ocorrências, gravidades e detecções) acionados por regras. Ajuda a gerenciar incidentes recorrentes e estabelecer táticas de redução de riscos.
- **Painel de Visão Geral do Login do Usuário (User Login Overview):** Fornece informações sobre o comportamento de acesso do usuário, ajudando a identificar atividades incomuns (ex.: login em vários locais simultaneamente) para reduzir ameaças e vulnerabilidades.

MODULO 4: Playbooks

Playbook

É um manual que providencia detalhes sobre qualquer ação operacional. Os manuais também esclarecem quais ferramentas devem ser usadas em resposta a um incidente de segurança. No campo da segurança, os manuais são essenciais. Urgência, eficiência e precisão são necessárias para identificar e mitigar rapidamente uma ameaça à segurança e reduzir o risco potencial. Os manuais garantem que as pessoas sigam uma lista consistente de ações de uma forma prescrita, independentemente de quem esteja trabalhando no caso.

Diferentes tipos de manuais são usados. Isso inclui manuais para resposta a incidentes , alertas de segurança e finalidades específicas para equipes e produtos.

Os manuais são acompanhados de uma Estratégia. A Estratégia descreve as expectativas dos Membros da equipe aos quais é atribuída uma tarefa, e alguns manuais também listam os indivíduos responsáveis. As expectativas delineadas são acompanhadas por um plano. O plano determina como a tarefa específica descrita no manual deve ser concluída.

Os manuais devem ser tratados como documentos vivos, o que significa que são atualizados com frequência pelos membros da equipe de segurança para abordar as mudanças no setor e as novas ameaças. Os manuais são geralmente gerenciados como um esforço de colaboração, uma vez que os membros da equipe de segurança têm diferentes níveis de especialização.

As atualizações geralmente são feitas se:

- Uma falha é identificada, como uma supervisão nas políticas e nos procedimentos delineados ou no próprio playbook.
- Houver uma mudança nos padrões do setor, como mudanças nas leis ou na conformidade regulatória.
- O cenário da segurança cibernética muda devido à evolução das táticas e técnicas dos agentes de ameaça.

Resposta a incidente

É a tentativa rápida de uma organização de identificar um ataque, conter dados e corrigir os efeitos de uma violação de segurança

Esses dois tipos de manuais são semelhantes, pois ambos contêm listas predefinidas e atualizadas de etapas a serem executadas ao responder a um incidente.Esses manuais também ajudam a minimizar erros e a garantir que ações importantes sejam executadas em um prazo específico.

Quando ocorre ou é identificado um incidente, uma ameaça ou uma vulnerabilidade, o nível de risco para a organização depende do dano potencial aos seus recursos. Uma fórmula básica para determinar o nível de risco é que o risco é igual à probabilidade de uma ameaça. Por esse motivo, um senso de urgência é essencial. Seguir as etapas descritas nos manuais também é importante se alguma tarefa forense estiver sendo realizada. O manuseio incorreto dos dados pode facilmente comprometer os dados forenses, tornando-os inutilizáveis.

Playbook de Resposta a Incidente

Um manual de resposta a incidentes é um guia com seis fases usado para ajudar a mitigar e gerenciar incidentes de segurança do início ao fim.

1. **Preparação** - Organização deve se preparar para mitigar a probabilidade, o risco e o impacto de um incidente de segurança documentando procedimentos, estabelecendo plano de pessoal e educando os usuários. A preparação estabelece uma base para uma resposta bem-sucedida a incidentes.
2. **Detecção e análise - O objetivo** dessa fase é detectar e analisar eventos usando processos e tecnologias definidos. O uso de ferramenta e estrategias apropriadas para essas fases ajuda o analista a determinar se uma violação ocorreu e analisar sua possível magnitude;
3. Contenção - O objetivo é evitar **danos maiores e reduzir o impacto de imediato de um incidente de segurança**. Sendo uma alta prioridade para as organizações porque ajuda a evitar riscos contínuos a ativos e dados críticos;
4. **Erradicação e recuperação** - Essa fase envolve a r**emoção completa dos artefatos de um incidente para que a organização possa retornar às operações normais**. Profissionais eliminam os artefatos de incidente

removendo códigos maliciosos e mitigando vulnerabilidades. Depois de exercerem a devida diligência, eles podem começar a restaurar o ambiente afetado para um estado seguro (restauração).

5. **Atividade pós incidente** - **DOcumentar o incidente, informar a liderança organizacional** e aplicar as lições aprendidas para garantir uma melhor preparação da a organização à futuros incidentes
6. **Cordenação:** A coordenação envolve r**elatar incidentes e compartilhar informações em todo o processo de resposta a incidentes**, com base nos padrões estabelecidos pela organização. Motiovs as quais a cordenação é importante:

- Garante que as organizações atendam aos requisitos de conformidade
- Permite uma resposta e resolução coordenadas

> As ferramentas e os manuais do SIEM funcionam juntos para fornecer uma maneira estruturada e eficiente de responder a possíveis incidentes de segurança.

Uma organização pode ter manuais específicos para lidar com diferentes tipos de ataques, como ransomware, malware, negação de serviço distribuída e muito mais.

As ações necessarias de um analista quando ele ao abordar um alerta:

1. **Avaliar o alertar** - A primeira ação no manual é determinar se é realmente válido identificando o motivo pelo qual o alerta foi gerado pelo SIEM. Isso pode ser feito analisando dados de registro e métricas relacionadas.
2. O manual descreve as ações e ferramentas a serem usadas para conter o malware e reduzir mais danos;
3. Descreve maneiras de eliminar todos os vestígios do incidente e restaurar as operações normais dos sistemas afetados.
4. O manual instrui o analista a realizar várias atividades pós-incidente e esforços de coordenação com a equipe de segurança. Algumas ações incluem a criação de um relatório final para comunicar o incidente de segurança às partes interessadas ou relatar o incidente às autoridades competentes.

O mais importante é entender que os manuais fornecem um processo consistente para os profissionais de segurança seguirem. Observe que os playbooks são documentos vivos, o que significa que a equipe de segurança fará mudanças , atualizações e melhorias frequentes para lidar com novas ameaças e vulnerabilidades.

Playbooks e ferramentas SOAR

Os manuais também são usados com as ferramentas SOAR. As ferramentas SOAR são semelhantes às ferramentas SIEM, pois são usadas para monitoramento de ameaças. O SOAR é um software usado para automatizar tarefas repetitivas geradas por ferramentas como o SIEM ou a detecção e resposta gerenciadas (MDR). Por exemplo, se um usuário tentar fazer o registro no computador muitas vezes com a senha errada, um SOAR bloquearia automaticamente a contabilização para impedir uma possível intrusão. Em seguida, os analistas consultariam um manual para tomar as medidas necessárias para resolver o problema